

CONFIDENTIAL // RESTRICTED ACCESS // USIU USE ONLY

UNIVERSITY SECURITY INVESTIGATION UNIT

SECURITY INVESTIGATION REPORT

CASE FILE #02

Operation Insider Whack-A-Mole

Case Reference	USIU-2026-INS-002
Threat Level	HIGH
Date of Report	June 26, 2026
Investigators	Felixandra Malicay Alfahad Adian
Program / Section	BSIT - 3C
Course	Information Assurance & Security II

00 EXECUTIVE SUMMARY

On the morning of the incident, the University Security Management Office issued a HIGH-threat security alert after indicators of unauthorized facility access and suspected data exfiltration were detected. The University Security Investigation Unit (USIU) was assigned to investigate physical security failures, personnel security gaps, policy weaknesses, and digital evidence tied to a recently resigned employee identified as the primary person of interest.

Findings confirm that the suspect exploited tailgating and CCTV blind spots to enter restricted areas after normal working hours. Those areas include the Research and Innovation Center, Registrar's Office, Data Center Facility, Human Resource Office, and Faculty Records Repository. Audit records show unauthorized USB usage, large-scale file copying, and deliberate deletion of logs and browser history. Key contributing factors were failed employee offboarding, excessive retained privileges, outdated security policies, and the absence of continuous security monitoring.

This report reconstructs the incident timeline, documents security failures across all affected domains, presents digital forensic findings, assesses institutional impact, and proposes targeted improvements grounded in Chapter 3 (Security Management) and Chapter 4 (Contingency Planning and Incident Response) of the course.

01 INCIDENT TIMELINE

Chronological reconstruction from resignation to detection, based on HR records, access logs, CCTV, and forensic artifacts.

DATE / TIME	EVENT	DESCRIPTION	SUPPORTING EVIDENCE
Approx. 2 weeks prior	Employee Resignation	Employee resigned. HR processed separation but did not complete security offboarding.	HR resignation and termination records.
Post-resignation (ongoing)	Failed Offboarding	Accounts, admin rights, and access cards remained active. University devices were not recovered.	AD records, privilege logs, card activity, asset inventory gaps.
Multiple after-hours dates	Unauthorized Facility Entries	Suspect entered restricted areas after hours including RIC, Registrar, Data Center, HR, and Faculty Records.	Access card logs showing after-hours entries; missing visitor access logs in affected zones.
Prior to server room entry	Tailgating Incident	Suspect followed an authorized employee through controlled entry and bypassed card authentication.	CCTV tailgating footage and incomplete visitor documentation.
11:37 PM	Server Room Unauthorized Entry	Suspect entered restricted Data Center server room and stayed inside for an extended period.	11:37 PM access logs and CCTV sequence with blind spot exploitation.
During after-hours access	Access to Sensitive Records	Confidential faculty, registrar, and HR records were accessed on university systems.	File access audits and application logs.
During workstation use	Data Exfiltration via USB	Personal USB was connected to workstation and used to copy large volumes of confidential files.	USB connection records, endpoint logs, bulk copy transfer logs.
Before detection	Evidence Tampering	Browser history, security logs, and selected documents were deleted to hide activity.	Recovered deleted artifacts, continuity gaps in logs, recovered fragments.
8:45 AM	Incident Detection	Security officers detected anomalies and launched formal USIU investigation. Threat level HIGH.	Security alert, officer findings report, and initial incident log.

02 SECURITY FAILURE ANALYSIS

This section addresses Phases 1 through 4 of the case. Each phase covers a distinct security domain directly implicated in the Operation Insider Whack-A-Mole incident.

PHASE 1 Physical Security Breach

DEFINITION OF PHYSICAL SECURITY

Physical security is the protection of personnel, hardware, software, networks, and tangible assets from unauthorized physical access, damage, or disruption. It includes access controls, surveillance systems, environmental safeguards, and structural barriers (Ch. 3 - Security Management).

PHYSICAL SECURITY WEAKNESSES IDENTIFIED

- Tailgating at controlled entry points allowed unauthorized entry without credential verification.
- CCTV blind spots were exploited, limiting visual coverage of suspect movement.
- Unauthorized after-hours access to a restricted server room (entry confirmed at 11:37 PM).
- Incomplete visitor documentation and missing visitor access logs in all five affected areas.
- No mantrap or anti-passback enforcement at sensitive facility zones.
- Insufficient monitoring and delayed response to repeated after-hours access anomalies.

HOW TAILGATING BYPASSES ACCESS CONTROL SYSTEMS

Access control systems authenticate only the person who presents a valid credential at the reader. In tailgating, an unauthorized individual follows an authenticated user through a doorway before it re-locks. The system registers a valid event for the authorized employee but has no mechanism to detect the second person. In this incident, tailgating provided the suspect access to a restricted floor and the Data Center server room despite having no active authorization.

WHY PHYSICAL SECURITY IS ESSENTIAL TO INFORMATION SECURITY

Logical controls such as firewalls and passwords assume that physical assets remain secure. Once an attacker gains physical access to servers or workstations, they can bypass authentication, install malware, directly copy data, or destroy logs. Physical security forms the foundation layer of the defense-in-depth model outlined in Chapter 3.

RECOMMENDED PHYSICAL ACCESS CONTROLS

- Deploy mantraps or security turnstiles at Data Center and Faculty Records entry points.
- Expand CCTV coverage to eliminate all blind spots; integrate real-time alerts with access logs.
- Require biometric plus RFID multi-factor authentication for server room access.
- Enforce strict anti-tailgating sensors with guard presence during off-hours.
- Implement mandatory visitor pre-registration, badge issuance, and authorized escort policy.
- Conduct quarterly physical security walkthroughs and penetration testing exercises.

HOW CCTV SYSTEMS SUPPORT SECURITY INVESTIGATIONS

CCTV provides time-stamped visual records that corroborate access control data. In this incident, footage confirmed tailgating, server room entry at 11:37 PM, and movement through restricted corridors. Beyond deterrence, CCTV assists investigators in constructing timelines, confirming identities, and presenting evidence in disciplinary or legal proceedings.

PHASE 2 Mobile Device and Data Handling Incident

KEY FACT: A personal USB device was used to copy large volumes of confidential university records from an internal workstation - bypassing all network-level controls.

WHY PORTABLE STORAGE DEVICES CREATE SECURITY RISKS

USB and removable media can store enormous amounts of data, are easy to conceal on a person, and connect directly to endpoints with no network traffic generated. This makes them ideal tools for insider data exfiltration - as demonstrated in this incident involving registrar, HR, and faculty records.

RISKS ASSOCIATED WITH MOBILE AND PORTABLE SYSTEMS

- Theft or loss of devices containing sensitive university data.
- Unauthorized access on devices that lack encryption or screen lock protections.
- Introduction of malware through unvetted external media inserted into university systems.
- Data exposure via unsecured wireless networks on portable devices off campus.
- Silent data leakage through offline transfers that leave no network-side log trail.

DEFINITION OF DATA LEAKAGE

Data leakage is the intentional or accidental transfer of confidential information from inside an organization to an unauthorized external destination. In this case, leakage occurred when confidential institutional files were copied from university systems to a personal USB device without authorization.

HOW REMOVABLE MEDIA BYPASS TRADITIONAL SECURITY CONTROLS

Network-based security tools - firewalls, intrusion detection systems, and web filters - monitor data leaving through network interfaces. Removable media transfers data through local USB connections, completely bypassing these perimeter defenses. Without endpoint DLP or USB port controls in place, an insider can exfiltrate data without triggering a single network-side alert.

RECOMMENDED POLICIES FOR EXTERNAL STORAGE DEVICES

- Prohibit personal USB devices on all university-managed workstations by default.
- Require written management approval and formal registration for any approved removable media.
- Mandate only university-issued, hardware-encrypted media for legitimate data transfers.
- Define clear consequences for policy violations within the Acceptable Use Policy (AUP).
- Conduct periodic random audits of endpoint removable media activity logs.

TECHNICAL CONTROLS TO REDUCE REMOVABLE MEDIA RISK

- USB port lockdown enforced via Group Policy or endpoint management platforms.
- Data Loss Prevention (DLP) rules blocking sensitive file types from being copied to USB.
- Endpoint Detection and Response (EDR) alerting on bulk or mass file copy events.
- Full-disk encryption on all university-owned laptops and desktop workstations.

- Mobile Device Management (MDM) controls for university-issued portable devices.

PHASE 3 Personnel Security Investigation

CRITICAL FAILURE: The suspect retained administrator rights, active accounts, and a functioning physical access card for two weeks after formally resigning from the university.

HOW PERSONNEL SECURITY SUPPORTS INFORMATION SECURITY

Personnel security governs the full employment lifecycle: background screening, security awareness training, role-based access assignment, behavioral monitoring, and secure separation. It reduces insider threat risk by ensuring that only vetted, properly trained, and correctly authorized individuals have access to sensitive systems. Chapter 3 stresses that no technology solution fully compensates for weak personnel security practices.

PRINCIPLE OF LEAST PRIVILEGE

The Principle of Least Privilege holds that users should receive only the minimum level of access required to perform their specific job duties - nothing more. In this case, the suspect retained broad administrator rights and physical access privileges well after separation, a direct violation of this principle that enabled the abuse of trusted access.

SECURITY FAILURES DURING EMPLOYEE SEPARATION

- User accounts remained active two full weeks after the resignation date.
- Administrator-level privileges were never revoked or downgraded.
- Physical access cards continued to function across multiple restricted locations.
- University-issued devices were not collected, inventoried, or remotely wiped.
- No joint HR and IT security exit checklist was completed upon separation.

WHY ACCOUNT DEACTIVATION IS CRITICAL AFTER TERMINATION

A separated employee is no longer bound by employment agreements and may pose an elevated risk, particularly if the departure was contentious or the motive for resignation is unclear. Immediate deactivation of all accounts, tokens, VPN credentials, and physical access badges closes the window for unauthorized post-employment access. In this incident, delayed offboarding granted the suspect weeks of unchallenged access to critical institutional systems.

RISKS CREATED BY EXCESSIVE PRIVILEGES

- Broader access to confidential registrar, HR, and faculty records than the role warranted.
- Ability to delete logs and conceal tracks - only possible with administrator-level control.
- Greater potential damage if credentials are sold, shared, or abused after employment ends.
- Difficulty detecting malicious activity when it blends with otherwise normal privileged operations.

RECOMMENDED PERSONNEL SECURITY AND OFFBOARDING PROCEDURES

- Trigger automated account disablement on the HR separation date - same day at maximum.
- Revoke physical access cards and collect all badges at the exit interview.

- Recover all university-issued hardware and perform forensic wipes before reassignment.
- Complete a joint HR, IT, and Security exit checklist with signed confirmation from all parties.
- Run a 30-day post-departure access audit to catch any orphaned accounts or lingering tokens.
- Apply and verify least privilege throughout employment via quarterly access certification reviews.

PHASE 4 Security Management and Maintenance Review

WHY INFORMATION SECURITY REQUIRES CONTINUOUS MAINTENANCE

Threats, vulnerabilities, and business processes change constantly. Security controls that were sufficient three years ago may leave critical gaps today. Chapter 3 describes security not as a one-time deployment but as a living cycle of planning, assessment, implementation, and ongoing review. Treating security as finished creates exactly the kind of environment that this incident exploited.

DEFINITION OF VULNERABILITY ASSESSMENT

A vulnerability assessment is a systematic process of identifying and evaluating weaknesses in systems, policies, and procedures that a threat actor could exploit. In a university context, this includes checking for unpatched systems, misconfigured access controls, CCTV coverage gaps, outdated training content, and incomplete policy frameworks.

RELATIONSHIP AMONG PLANNING, RISK ASSESSMENT, VULNERABILITY ASSESSMENT, AND REMEDIATION

Security management operates as a closed-loop lifecycle (Ch. 3):

1. Planning - Establish security policies, standards, and objectives aligned with the university's risk tolerance.
2. Risk Assessment - Identify and prioritize threats, critical assets, and potential institutional impact.
3. Vulnerability Assessment - Discover specific technical and procedural weaknesses that could materialize those risks.
4. Remediation - Deploy controls, apply patches, update policies, and deliver targeted training to close findings.
5. Monitoring and Review - Measure control effectiveness continuously and feed results back into the planning stage.

In this incident, three-year-old policies, infrequent assessments, and absent remediation allowed physical, personnel, and technical gaps to accumulate and go undetected until an active breach occurred.

ORGANIZATIONAL FAILURES THAT CONTRIBUTED TO THIS INCIDENT

- Security policies had not been reviewed or updated in three years.
- Vulnerability assessments were rarely conducted across physical and information systems.
- Employee security awareness training was outdated and not regularly refreshed.
- No comprehensive security audits had been completed in recent memory.
- No centralized monitoring existed to correlate after-hours access events with data transfers.

RECOMMENDED SECURITY MANAGEMENT IMPROVEMENTS

- Adopt an annual policy review cycle with formal governance committee approval.
- Schedule quarterly vulnerability assessments covering both physical and logical systems.
- Deliver role-specific security awareness training every semester with tracked completion.
- Commission annual third-party security audits with published remediation timelines.

- Establish a Security Operations Center (SOC) function or managed SIEM for real-time monitoring.

HOW CONTINUOUS MONITORING STRENGTHENS SECURITY PROGRAMS

Continuous monitoring (Ch. 4 - Incident Response) enables early detection of behavioral anomalies such as after-hours facility access, bulk file copy events, and suspicious log deletions. Real-time correlation alerts shorten the mean time to detect incidents and prevent situations from going unnoticed for weeks - as happened between the suspect's resignation and the 8:45 AM security alert in this case.

03 DIGITAL FORENSICS ANALYSIS (PHASE 5)

DEFINITION OF DIGITAL FORENSICS

Digital forensics is the application of scientific methods to identify, preserve, collect, analyze, and present digital evidence gathered from computers, storage media, logs, and network records. The goal is to produce findings suitable for organizational disciplinary action or formal legal proceedings (Ch. 4).

IMPORTANCE OF DIGITAL EVIDENCE

Digital evidence answers the fundamental investigative questions of who, what, when, where, and how. In this incident, recovered artifacts can establish that the suspect's account accessed confidential files, that a USB device was connected and used for bulk transfers, and that logs were deliberately deleted - creating a chain of digital evidence that ties the physical intrusion directly to the data exfiltration.

FIVE PHASES OF THE DIGITAL FORENSICS PROCESS

- 1. Identification** Recognize potential evidence sources: the suspect's workstation, USB artifacts, access control records, CCTV storage, Active Directory logs, and application audit trails.
- 2. Preservation** Isolate the workstation from the network, create verified forensic bit-stream images of all storage media, generate hash values (MD5 or SHA-256), and prevent any alteration.
- 3. Collection** Acquire all identified evidence using forensically sound tools while maintaining full chain of custody documentation from the moment of first contact.
- 4. Analysis** Examine recovered files, deleted artifacts, USB registry entries, and file system metadata. Correlate timestamps with access control logs and CCTV footage.
- 5. Presentation** Document all findings in a formal investigation report structured for management, HR disciplinary review, or submission to law enforcement.

WHY EVIDENCE PRESERVATION IS CRITICAL

Improper handling can alter timestamps, overwrite deleted file clusters, or introduce contaminants that make evidence inadmissible in formal proceedings. Preservation ensures the integrity of disk images and log files so that analysis accurately reflects the true state of systems at the time of the incident.

CHAIN OF CUSTODY

Chain of custody is a chronological, documented record detailing who collected evidence, when it was collected, how it was stored, and who accessed it at each stage. Every handler signs and timestamps their entry. A properly maintained chain of custody proves that evidence has not been altered or tampered with - a prerequisite for admissibility in any disciplinary hearing or legal proceeding.

DIGITAL EVIDENCE SOURCES IN THIS CASE

- Forensic image of the suspect's university workstation hard drive.
- Recovered deleted documents and associated file system metadata.
- Deleted and forensically recovered browser history.
- USB connection and removal registry artifacts from the workstation.
- File transfer and endpoint audit logs showing bulk copy activity.
- Active Directory and account activity logs for the suspect's credentials.
- Access control system logs for all five restricted areas.
- CCTV recordings from the Research and Innovation Center, Data Center, and adjacent corridors.
- HR separation records and incomplete offboarding documentation.

INVESTIGATIVE FINDINGS

- Confirmed unauthorized physical access to multiple restricted facilities after normal hours.
- CCTV and access logs verify tailgating and server room entry at 11:37 PM.
- Large-scale copying of confidential files to a personal USB device confirmed by audit logs.
- Deliberate deletion of browser history and security logs demonstrates clear intent to conceal.
- Former employee retained and abused administrator-level privileges post-separation.

HOW FORENSIC FINDINGS SUPPORT DISCIPLINARY OR LEGAL PROCEEDINGS

Forensic artifacts provide objective, reproducible proof of misconduct that is difficult to dispute. USB connection logs and file transfer records demonstrate unauthorized data possession. Recovered deleted files and log gaps support a finding of deliberate concealment, which is relevant to assessing intent. CCTV footage correlated with access control logs places the person of interest at the scene of each physical breach. Collectively, this body of evidence supports university disciplinary action, civil claims for institutional damages, and potential criminal referral under applicable data privacy and computer misuse laws. Chapter 4 specifically notes that preserved evidence with an unbroken chain of custody is the foundation for admissibility in any formal proceeding.

04 IMPACT ANALYSIS

Operational Impact

- Temporary restriction of affected systems during active investigation and remediation phases.
- Significant additional workload placed on IT, security, and HR teams for log review and interviews.
- Service disruptions to registrar and faculty records offices pending data integrity verification.
- Widespread loss of confidence in the effectiveness of existing access control and monitoring systems.

Financial Consequences

- Direct labor costs for forensic investigation, incident response, and remediation activities.
- Capital expenditure for CCTV upgrades, DLP deployment, and physical access control improvements.
- Potential regulatory fines or sanctions if compromised data falls under applicable privacy laws.
- Litigation defense costs and possible settlement exposure if affected parties pursue legal action.

Reputational Damage

- Erosion of trust among students, faculty, staff, and partner institutions.
- Potential negative media attention if the breach becomes publicly known.
- Long-term damage to the university's credibility as a trustworthy steward of research and personal data.

Legal Implications

- Potential violations of data privacy regulations covering student and employee records.
- Civil liability exposure from data subjects whose information was accessed without consent.
- Possible criminal referral for unauthorized computer access and data theft.
- Breach notification obligations depending on data classification and applicable jurisdiction.

Privacy Concerns

- Unauthorized access to and potential exfiltration of faculty employment and personnel files.
- Potential compromise of student academic records held by the Registrar's Office.
- Identity theft risk if HR files containing personal identifiers were copied to the USB device.
- Long-term privacy harm to individuals whose data was taken without their knowledge or consent.

05 SECURITY IMPROVEMENT PLAN

Physical Security Improvements

- Install mantraps and anti-tailgating sensors at the Data Center and all high-value research areas.
- Eliminate CCTV blind spots across all five affected facilities; retain footage for 90 days minimum.
- Require biometric plus card multi-factor authentication for server room access.
- Enforce electronic visitor management with mandatory authorized escorts in restricted zones.

Personnel Security Improvements

- Automate same-day account and badge deactivation triggered directly by the HR separation event.
- Mandate a joint HR, IT, and Security offboarding checklist for every employee departure.
- Conduct quarterly access recertification reviews for all privileged and administrator accounts.
- Configure monitoring rules to flag insider threat indicators such as after-hours access combined with bulk download activity.

Security Maintenance Strategies

- Schedule annual policy reviews with formal board-level approval for all information security policies.
- Conduct quarterly vulnerability assessments covering both physical and logical control layers.
- Deliver semester-based, role-specific security awareness training with documented completion tracking.
- Commission an independent annual security audit with a published remediation roadmap.

Forensic Readiness Recommendations

- Maintain centralized logging with tamper-evident storage and defined minimum retention periods.

- Document evidence handling procedures in line with Chapter 4 incident response guidelines.
- Pre-stage forensic imaging tools and designate trained, certified evidence custodians.
- Run tabletop incident response exercises that specifically include insider threat scenarios.
- Establish a legal liaison protocol for cases that may require law enforcement referral.

06 CYBERSECURITY AND SECURITY MANAGEMENT RECOMMENDATIONS

The following eight recommendations are prioritized for a university environment. Each one directly addresses a root cause identified through this investigation.

- 01

Implement Multi-Factor Physical Access Controls - Require biometric verification combined with RFID badges at the Data Center, Faculty Records Repository, and Research and Innovation Center to eliminate tailgating vulnerabilities at the physical entry layer.
- 02

Enforce Immediate Offboarding Controls - Integrate the HR separation workflow with IT systems to automatically disable all accounts, revoke VPN tokens, and deactivate physical access badges within 24 hours of an employee's final working day (Ch. 3 - Personnel Security).
- 03

Restrict and Monitor All Removable Media - Block unauthorized USB ports by default on all university workstations. Allow only registered, encrypted, university-issued media with active DLP monitoring enabled.
- 04

Deploy Data Loss Prevention Technology - Configure endpoint DLP to alert on and block the bulk transfer of classified registrar, HR, and faculty file types to external media or unauthorized cloud storage destinations.
- 05

Establish Continuous Security Monitoring - Implement SIEM correlation rules that link after-hours physical access events with anomalous file transfer activity to generate real-time insider threat alerts (Ch. 4 - Incident Detection).
- 06

Strengthen Security Governance and Maintenance - Adopt a formal annual security calendar that covers policy review, vulnerability assessment, audit scheduling, and awareness training. No control or policy should go longer than one cycle without review and documented reassessment.
- 07

Build Forensic and Incident Response Readiness - Maintain forensic toolkits, chain-of-custody forms, and a dedicated insider threat response playbook so future incidents can be investigated promptly without risking evidence spoliation or procedural failure.
- 08

Expand Security Awareness Training on Insider Threats - Train all staff to challenge unfamiliar individuals in restricted areas, report tailgating observations, and recognize social engineering attempts. Technology controls are most effective when supported by an informed and security-conscious campus community.

07 CONCLUSION

Operation Insider Whack-A-Mole revealed a compounding series of failures across physical security, personnel lifecycle management, endpoint data controls, and security governance. The incident was not the product of a single technical flaw. It resulted from the accumulated effect of unchallenged tailgating, retained post-resignation privileges, unrestricted removable media use, and three years of deferred security maintenance.

The name of the operation is fitting: each security gap enabled the next. Fixing only one layer without addressing the others would have left the university equally exposed. The recommendations in this report target root causes holistically and are designed to reduce insider threat exposure, shorten detection windows, and ensure that future incidents can be investigated and resolved with legally sound, well-preserved evidence.

Respectfully submitted by:

Felixandra Malicay	Alfahad Adian
Investigator, USIU	Investigator, USIU
BSIT - 3C	June 26, 2026